Architecture réseau: Problèmes de conception coupe-feu

GEF330 – Hiver 2021
CRI13

Mariam El Mezouar
Collège Militaire Royal du Canada
Génie électrique et génie informatique
Mariam.el-mezouar@rmc-cmr.ca
elmezouar.segfaults.net

References

- NetFilter/iptables de Daniel Miessler, http://www.danielmiessler.com/study/iptables/

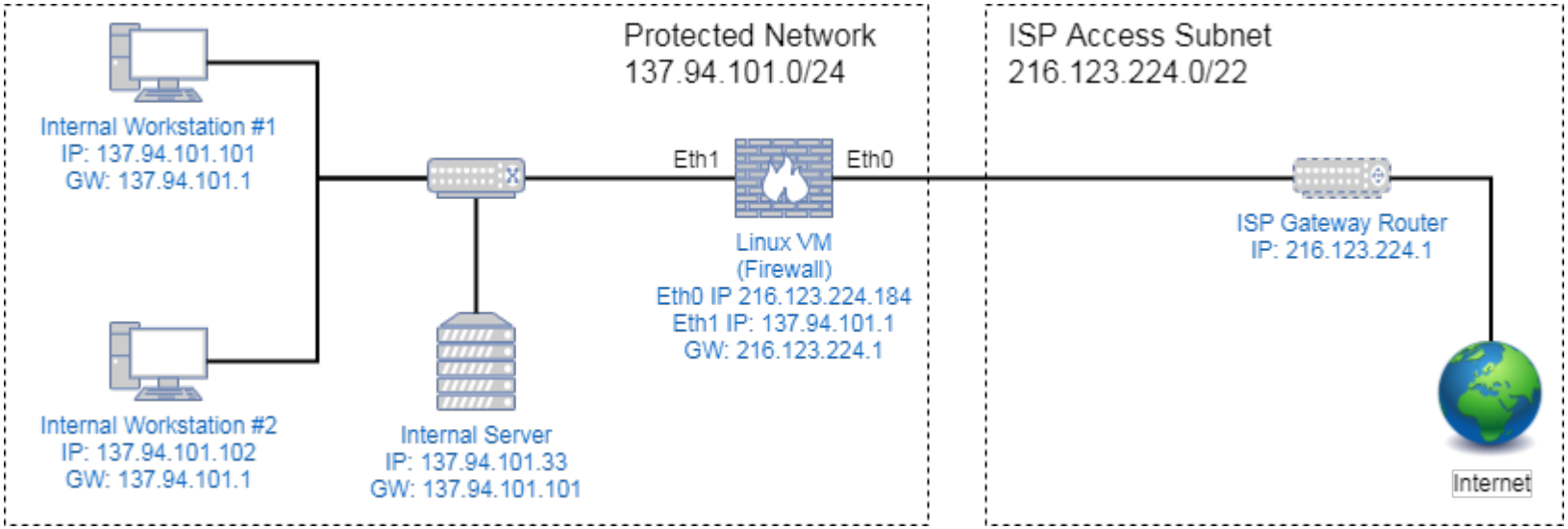
Aperçu

- Commencer avec un scénario de départ raisonnable

- Puis ajouter des scénarios d'attaques et faire la conception de solutions de coupe-feu
  - Porte dérobée clandestine (Backdoor)
  - balayage
  - Attaque de Mitnick
  - Tunnel HTTP inversé
  - Mouvements latéraux

- Nous allons vous donner les informations sur l'attaque… Vous allez chercher à découvrir pourquoi le firewall ne l'a pas bloqué et comment le corriger.

Votre réseau




```
#policy
iptables –P INPUT DROP
iptables –P FORWARD DROP
iptables –P OUTPUT DROP

#Allow pinging firewall to anywhere
iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT
iptables -A INPUT -p icmp --icmp-type echo-reply -j ACCEPT

# Allow ping from protected network to anywhere
iptables -A FORWARD -p icmp --icmp-type echo-request -j ACCEPT
iptables -A FORWARD -p icmp --icmp-type echo-reply -j ACCEPT

#Allow ssh
iptables -A FORWARD -p tcp --dport 22 -j ACCEPT
iptables -A FORWARD -p tcp --sport 22 -j ACCEPT
```

```
#Allow web access
iptables -A FORWARD -p tcp --dport 80 -j ACCEPT
iptables -A FORWARD -p tcp --sport 80 -j ACCEPT
```

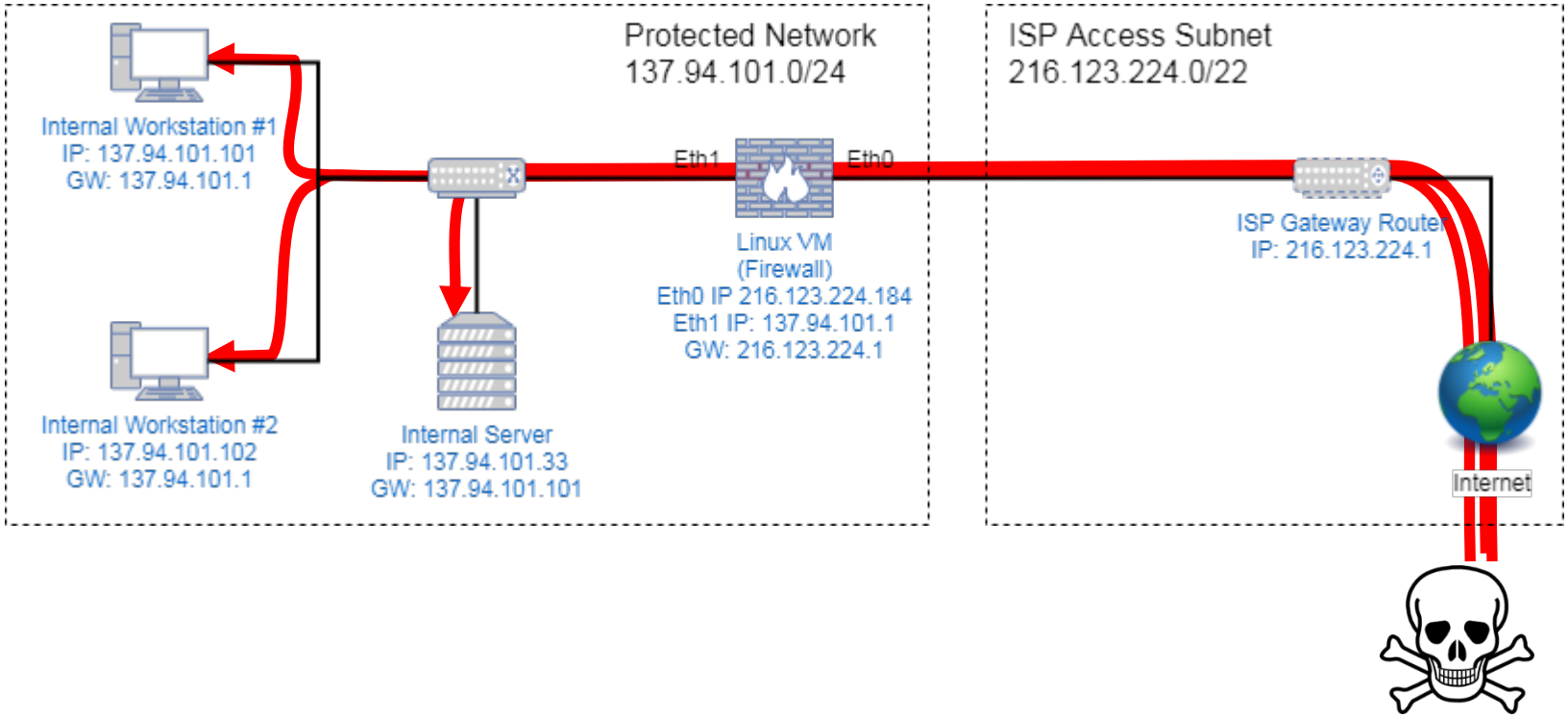
#Notez que le serveur interne propose des services Web et SSH qui devraient être accessibles aux utilisateurs internes.

Scenario #1: Balayage (Scan)

- Tout est calme les premiers jours…
- Ensuite, vous remarquez un pic étrange dans l'activité du réseau… quelqu'un a scanné les machines de votre réseau!
- Une analyse plus approfondie révèle comment cela a été fait:
  - L'attaquant a pu envoyer une requête ping aux périphériques de notre réseau afin d'établir une carte de votre réseau.
  - Ils ont ensuite utilisé des paquets TCP SYN pour trouver des ports ouverts sur chaque hôte interne.
- Pourquoi est-ce un problème sérieux ?
- Pourquoi nos règles de pare-feu n'ont-elles pas bloqué cela ??

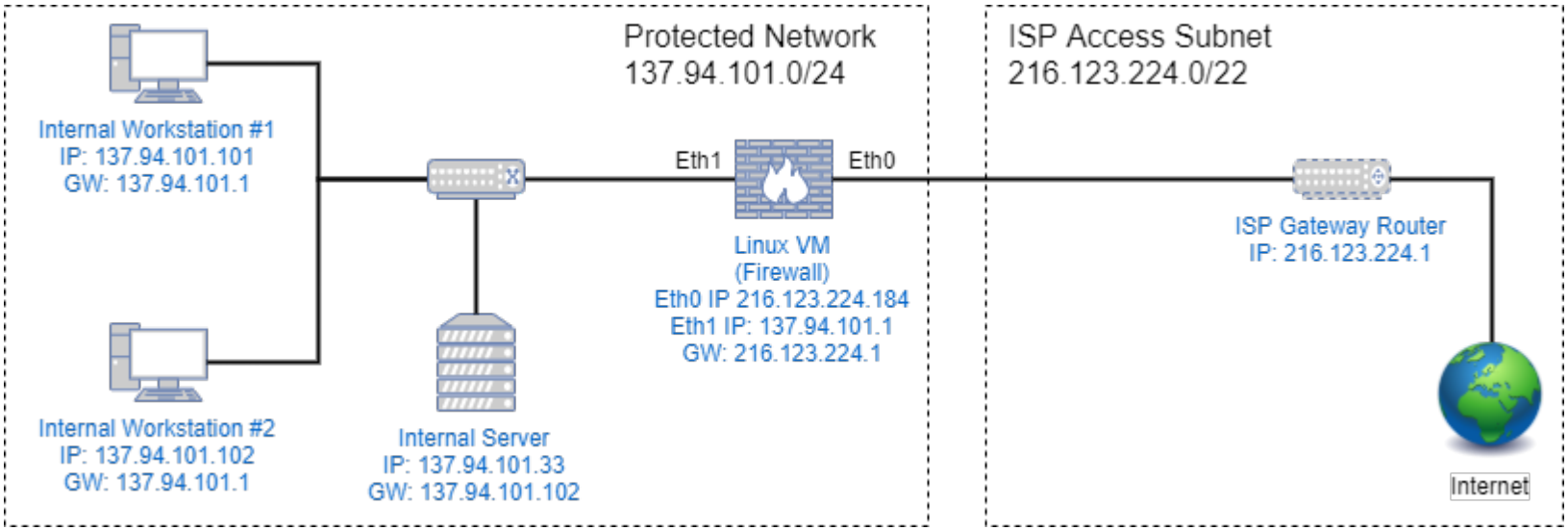
- Dans votre solution, limitez-vous à résoudre ce problème spécifiquement.

Scenario #1: Balayage



Port_scan.pcap

Solution ??

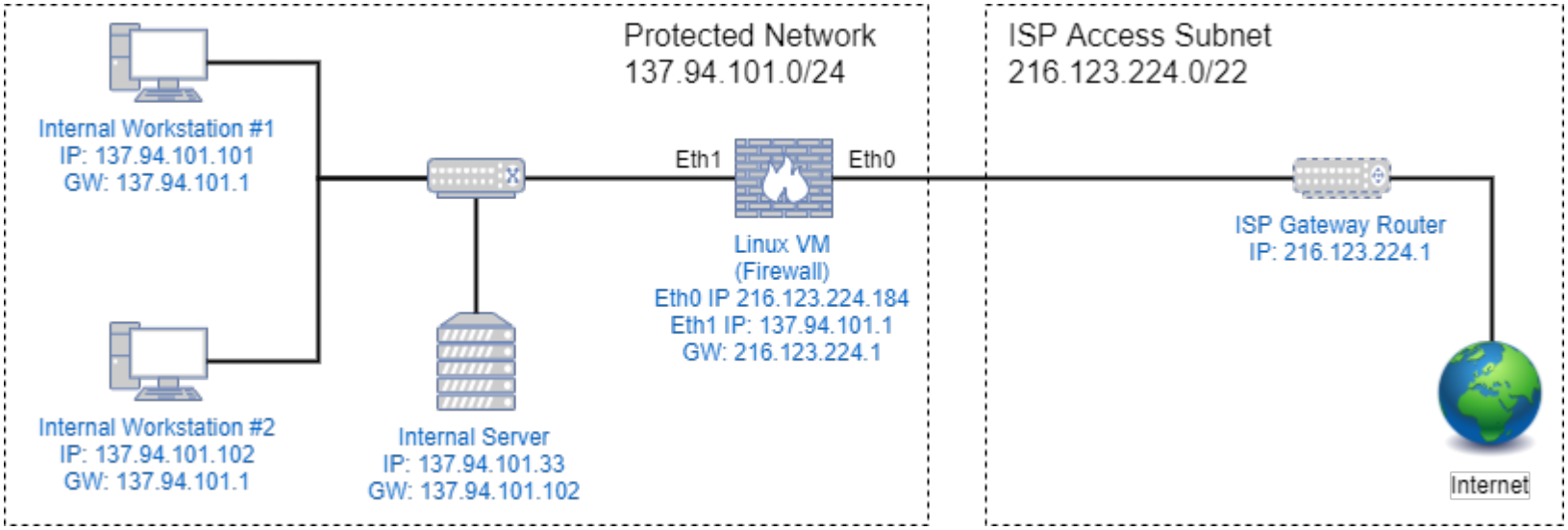



```
#policy
iptables –P INPUT DROP
iptables –P FORWARD DROP
iptables –P OUTPUT DROP

#Allow pinging firewall to anywhere
iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT
iptables -A INPUT -p icmp --icmp-type echo-reply -j ACCEPT

# Allow ping from protected network to anywhere
iptables -A FORWARD -p icmp --icmp-type echo-request -j ACCEPT
iptables -A FORWARD -p icmp --icmp-type echo-reply -j ACCEPT

#Allow ssh
iptables -A FORWARD -p tcp --dport 22 -j ACCEPT
iptables -A FORWARD -p tcp --sport 22 -j ACCEPT
```

```
#Allow web access
iptables -A FORWARD -p tcp --dport 80 -j ACCEPT
iptables -A FORWARD -p tcp --sport 80 -j ACCEPT
```

#Note that the Internal Server offers both Web and SSH services that should be accessible to internal users.

Solution!




```
#policy
iptables –P INPUT DROP
iptables –P FORWARD DROP
iptables –P OUTPUT DROP

#Allow pinging firewall to anywhere
iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT
iptables -A INPUT -p icmp --icmp-type echo-reply -j ACCEPT

# Allow ping from protected network to anywhere
iptables -A FORWARD –s 137.94.101.0/24 -p icmp --icmp-type echo-request -j ACCEPT
iptables -A FORWARD –d 137.94.101.0/24 -p icmp --icmp-type echo-reply -j ACCEPT

#Allow ssh
iptables -A FORWARD –s 137.94.101.0/24  -p tcp --dport 22 -j ACCEPT
iptables -A FORWARD –d 137.94.101.0/24  -p tcp --sport 22 -j ACCEPT
```

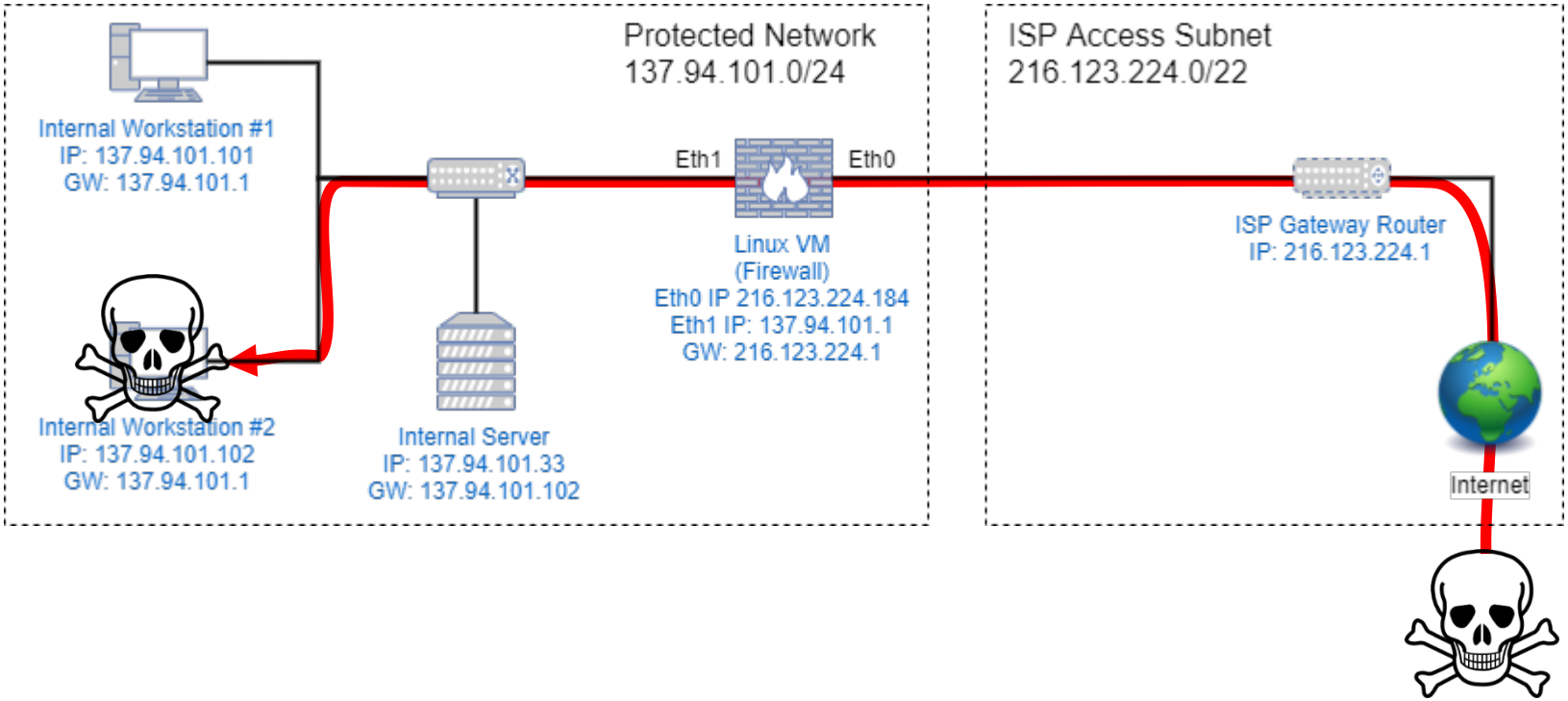
```
#Allow web access
iptables -A FORWARD –d 137.94.101.0/24 -p tcp --dport 80 -j ACCEPT
iptables -A FORWARD –s 137.94.101.0/24 -p tcp --sport 80 -j ACCEPT
```

#Note that the Internal Server offers both Web and SSH services that should be accessible to internal users.

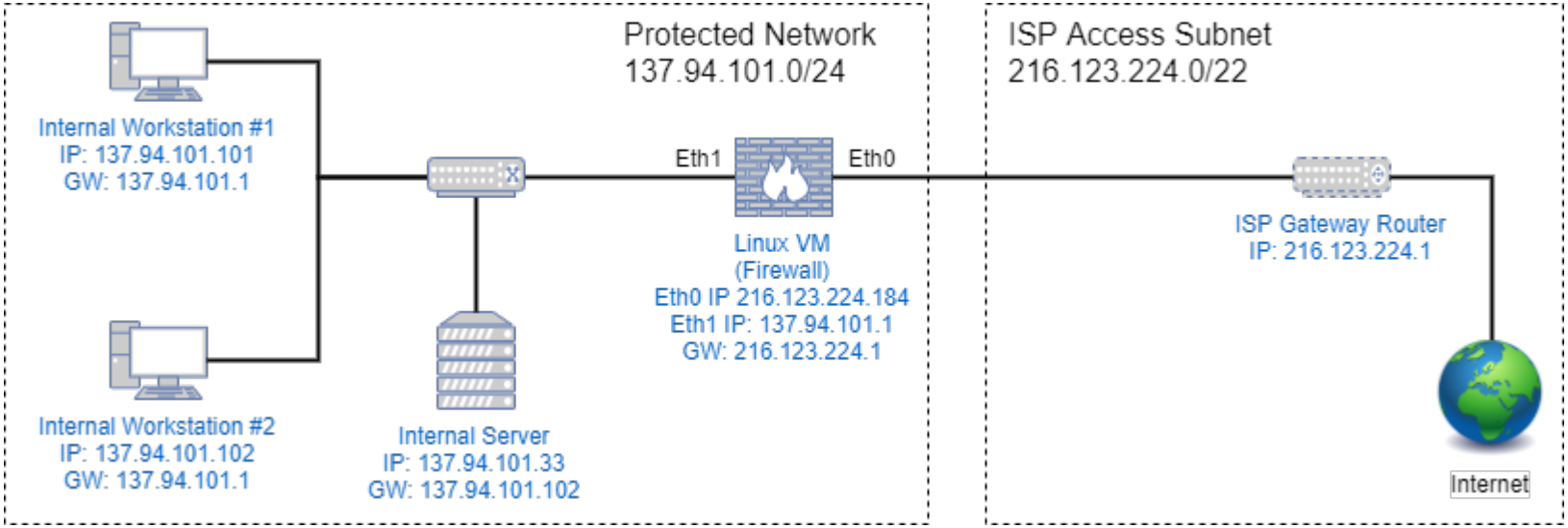
Scenario #2: Porte dérobée

- Tout va bien pour les prochains jours, et alors… CATASTROPHE!
- Workstation #2 détenait des dossiers financiers confidentiels. Détenait... Mais d’une manière ou d’une autre, ils se sont retrouvés sur un forum Web public.
- Une enquête approfondie a révélé que quelqu'un avait accédé à Workstation #2 depuis Internet via une porte dérobée SSH à l'aide du port 22.
- Le malware qui a ouvert le port a été supprimé. Mais comment aurions-nous pu bloquer cela au niveau du pare-feu? (Les utilisateurs doivent pouvoir utiliser SSH vers Internet.)

Scenario #2: Porte dérobée



Solution ??



#policy
iptables –P INPUT DROP
iptables –P FORWARD DROP
iptables –P OUTPUT DROP

#Allow pinging firewall to anywhere
iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT
iptables -A INPUT -p icmp --icmp-type echo-reply -j ACCEPT

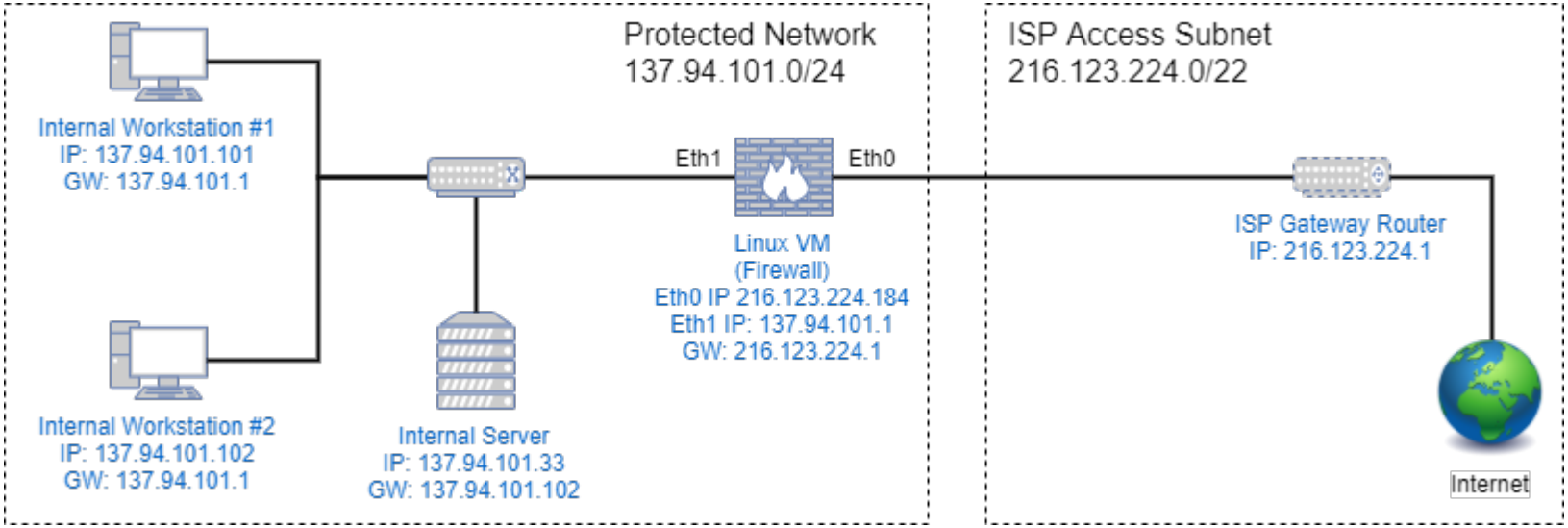
Allow ping from protected network to anywhere
iptables -A FORWARD *–s 137.94.101.0/24* -p icmp --icmp-type echo-request -j ACCEPT
iptables -A FORWARD *–d 137.94.101.0/24* -p icmp --icmp-type echo-reply -j ACCEPT

#Allow ssh
iptables -A FORWARD *–s 137.94.101.0/24* -p tcp --dport 22 -j ACCEPT
iptables -A FORWARD *–d 137.94.101.0/24* -p tcp --sport 22 -j ACCEPT

#Allow web access
iptables -A FORWARD *–d 137.94.101.0/24* -p tcp --dport 80 -j ACCEPT
iptables -A FORWARD –s *137.94.101.0/24* -p tcp --sport 80 -j ACCEPT

#Note that the Internal Server offers both Web and SSH services that should be accessible to internal users.

Solution!




```
#policy
iptables –P INPUT DROP
iptables –P FORWARD DROP
iptables –P OUTPUT DROP

#Allow pinging firewall to anywhere
iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT
iptables -A INPUT -p icmp --icmp-type echo-reply -j ACCEPT

# Allow ping from protected network to anywhere
iptables -A FORWARD –s 137.94.101.0/24 -p icmp --icmp-type echo-request -j ACCEPT
iptables -A FORWARD –d 137.94.101.0/24 -p icmp --icmp-type echo-reply -j ACCEPT

#Allow ssh
iptables -A FORWARD –s 137.94.101.0/24  -p tcp --dport 22 -m state --state NEW,
        ESTABLISHED -j ACCEPT
iptables -A FORWARD –d 137.94.101.0/24  -p tcp --sport 22 –m state –state
        ESTABLISHED -j ACCEPT
```

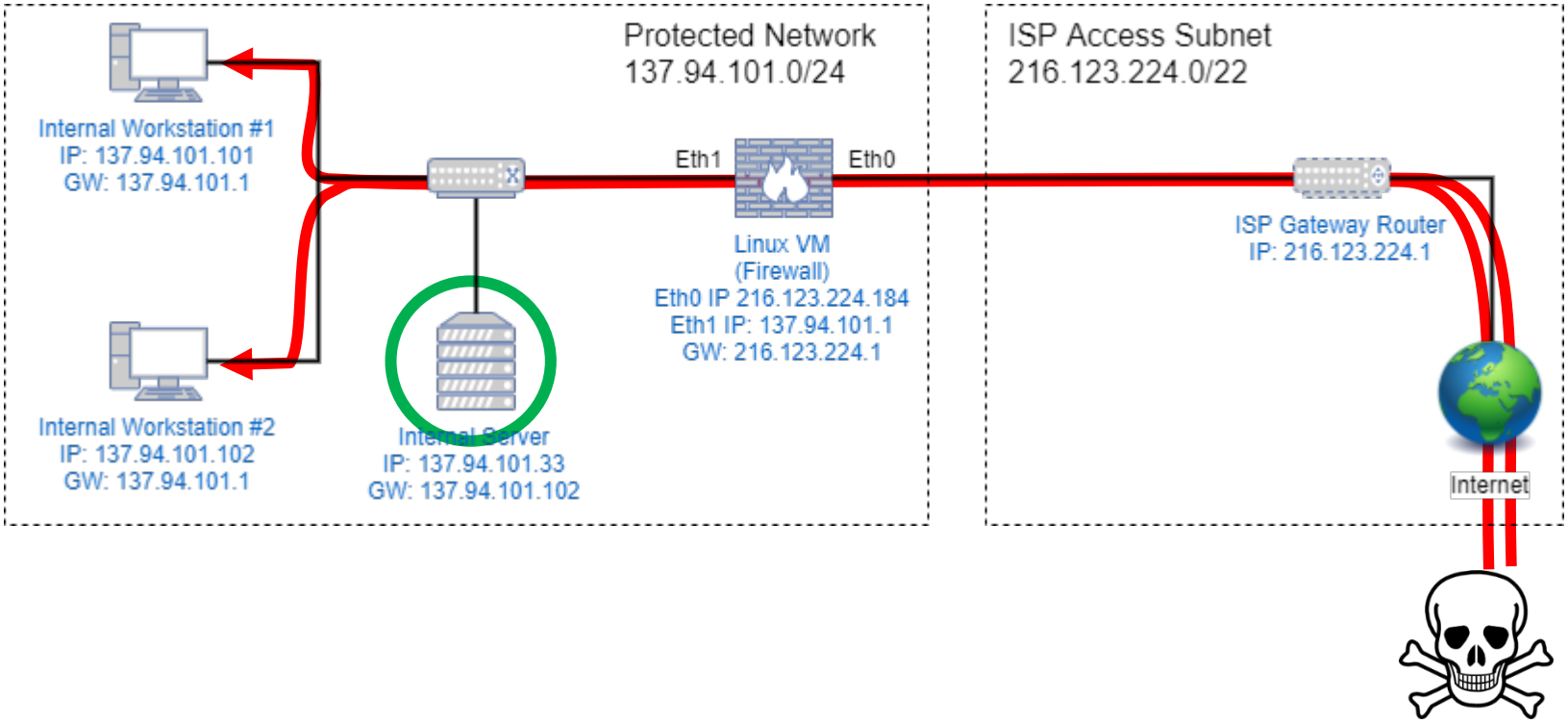
```
#Allow web access
iptables -A FORWARD –s 137.94.101.0/24 -p tcp --dport 80 22 -m state --
        state NEW, ESTABLISHED -j ACCEPT
iptables -A FORWARD –d 137.94.101.0/24 -p tcp --sport 80 –m state –state
        ESTABLISHED -j ACCEPT
```

#Note that the Internal Server offers both Web and SSH services that should be accessible to internal users.

Scenario #3: Serveur Web Publique

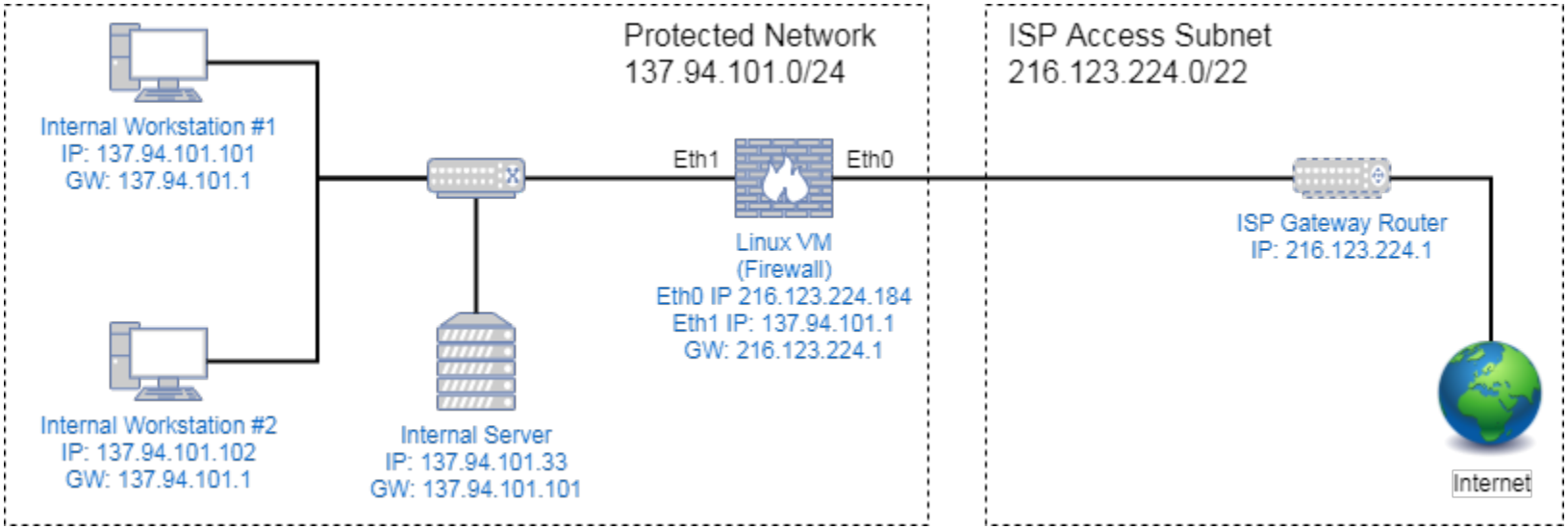
- Votre entreprise décide que le serveur interne doit être accessible en dehors de votre réseau interne pour HTTP.
- Vous avez enfin obtenu votre réseau correctement sécurisé. Mais dès que vous ouvrez votre pare-feu pour autoriser HTTP, vous commencez à visualiser un trafic étrange vers le port 80 de vos Workstations.
- Vous restaurez rapidement vos règles sécurisées… mais maintenant votre patron est en colère parce que le serveur interne est… enfin… toujours uniquement interne.
- Comment résolvez-vous cela?

Scenario #3: Serveur Web Publique



Port_scan.pcap

Solution ??

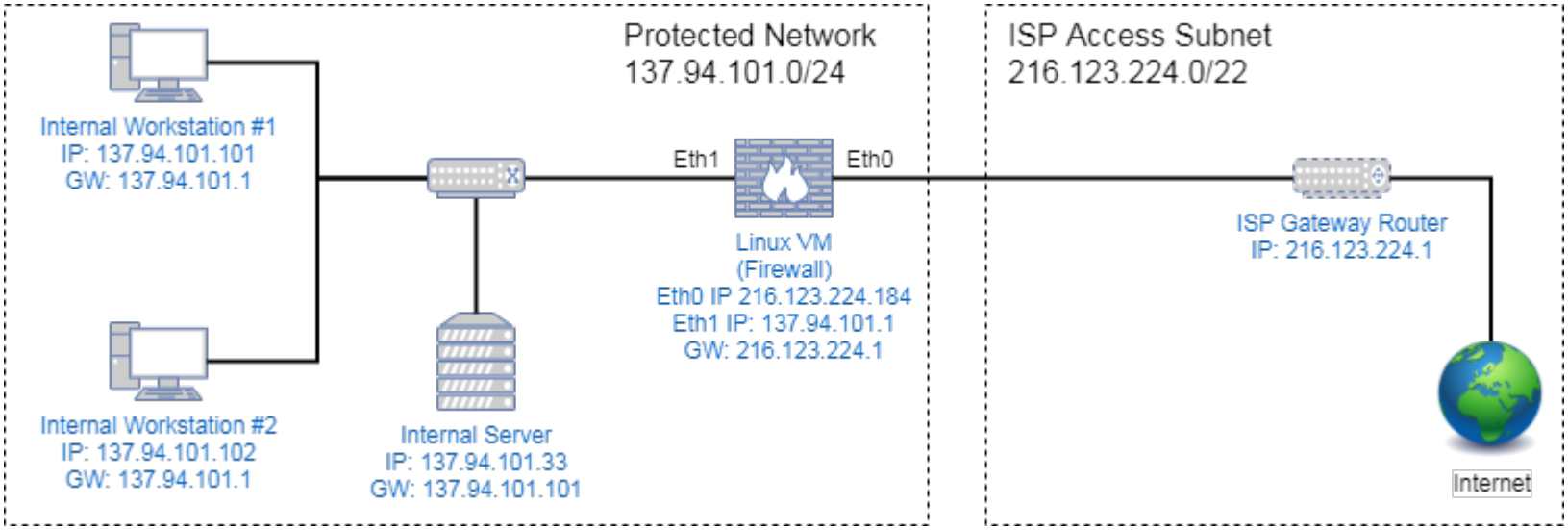



```
#policy
iptables –P INPUT DROP
iptables –P FORWARD DROP
iptables –P OUTPUT DROP

#Allow pinging firewall to anywhere
iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT
iptables -A INPUT -p icmp --icmp-type echo-reply -j ACCEPT

# Allow ping from protected network to anywhere
iptables -A FORWARD –s 137.94.101.0/24 -p icmp --icmp-type echo-request -j ACCEPT
iptables -A FORWARD –d 137.94.101.0/24 -p icmp --icmp-type echo-reply -j ACCEPT

#Allow ssh
iptables -A FORWARD –s 137.94.101.0/24  -p tcp --dport 22 -m state --state NEW,
        ESTABLISHED -j ACCEPT
iptables -A FORWARD –d 137.94.101.0/24  -p tcp --sport 22 –m state –state
        ESTABLISHED -j ACCEPT
```

```
#Allow web access
iptables -A FORWARD –s 137.94.101.0/24 -p tcp --dport 80 22 -m state --
        state NEW, ESTABLISHED -j ACCEPT
iptables -A FORWARD –d 137.94.101.0/24 -p tcp --sport 80 –m state –state
        ESTABLISHED -j ACCEPT
```

#Note that the Internal Server offers both Web and SSH services that should be accessible to internal users.

Solution!




```
#policy
iptables –P INPUT DROP
iptables –P FORWARD DROP
iptables –P OUTPUT DROP

#Allow pinging firewall to anywhere
iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT
iptables -A INPUT -p icmp --icmp-type echo-reply -j ACCEPT

# Allow ping from protected network to anywhere
iptables -A FORWARD –s 137.94.101.0/24 -p icmp --icmp-type echo-request -
        j ACCEPT
iptables -A FORWARD –d 137.94.101.0/24 -p icmp --icmp-type echo-reply -j
        ACCEPT

#Allow ssh
iptables -A FORWARD -s 137.94.101.0/24 -p tcp --dport 22 -m state --state
NEW, ESTABLISHED -j ACCEPT
iptables -A FORWARD -d 137.94.101.0/24 -p tcp --sport 22 -m state --state
ESTABLISHED -j ACCEPT
```

```
#Allow web access
iptables -A FORWARD -s 137.94.101.0/24 -p tcp --dport 80 -m state --state NEW, ESTABLISHED
-j ACCEPT
iptables -A FORWARD -d 137.94.101.0/24 -p tcp --sport 80 -m state --state ESTABLISHED -j
ACCEPT

#Allow Web Access to Internal Server
Iptables –A FORWARD –d 137.94.101.33 –p tcp –dport 80 -m state --state NEW, ESTABLISHED
        –j
ACCEPT
Iptables –A FORWARD –s 137.94.101.33 –p tcp –sport 80 -m state --state ESTABLISHED -j
        ACCEPT
```

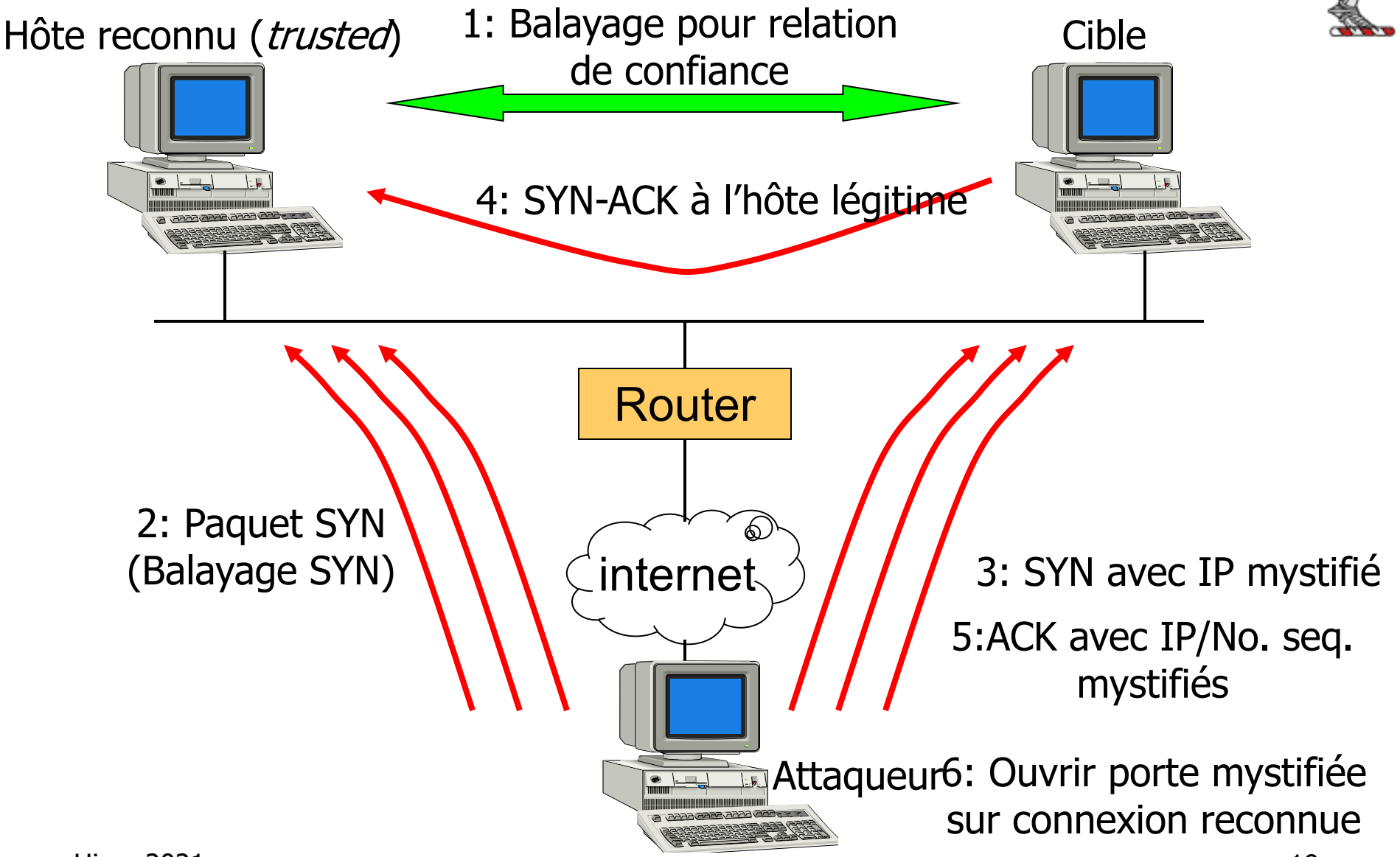
Scénario d'attaque #4: Fameuse attaque de Kevin Mitnick

- Kevin Mitnick a attaqué les systèmes de Tsutomu Shimomura en 1994
- Utilise un barrage de SYN et détournement (*hijacking*) TCP aussi appelé mystification (*spoofing*)

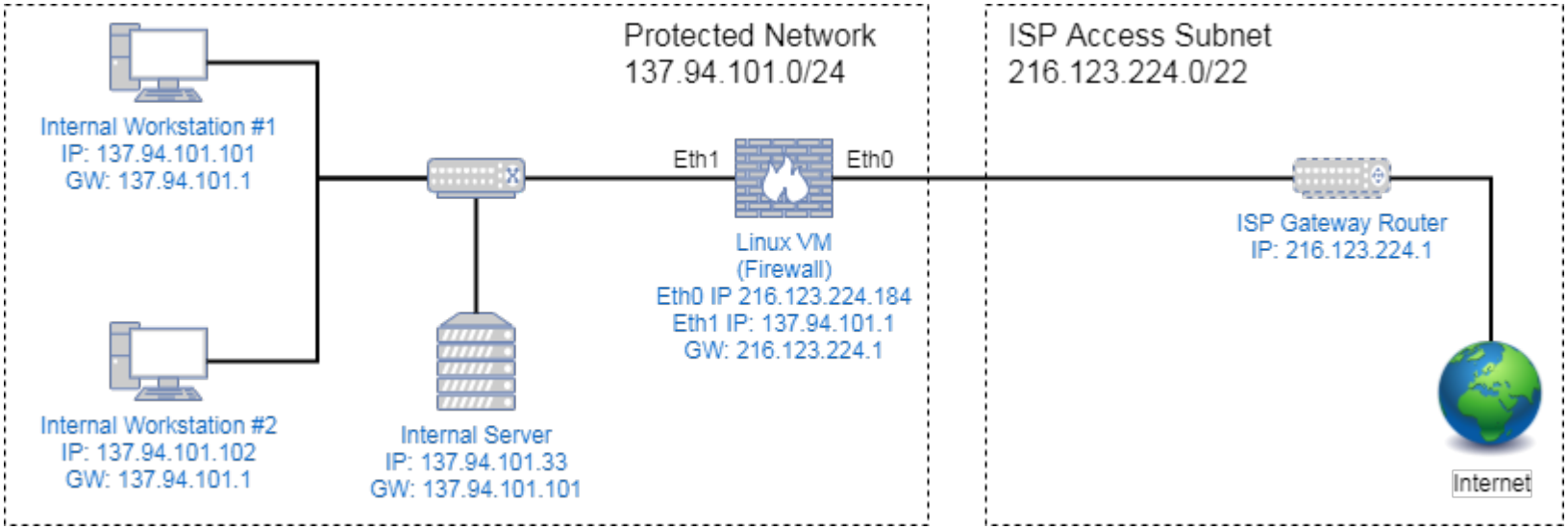
Scenario #4 : Attaque de Mitnick

- Votre serveur web fonctionne correctement et tout semble aller bien.
- Vous parcourez les journaux de votre réseau et vous constatez une fois de plus que le poste de travail n ° 2 a été compromis!
- Ce qui est vraiment déroutant, c'est que bien que le trafic illicite de la station de travail n ° 2 passe par le pare-feu… il semble communiquer avec un appareil de votre propre sous-réseau?

Attaque de Mitnick



Solution ??



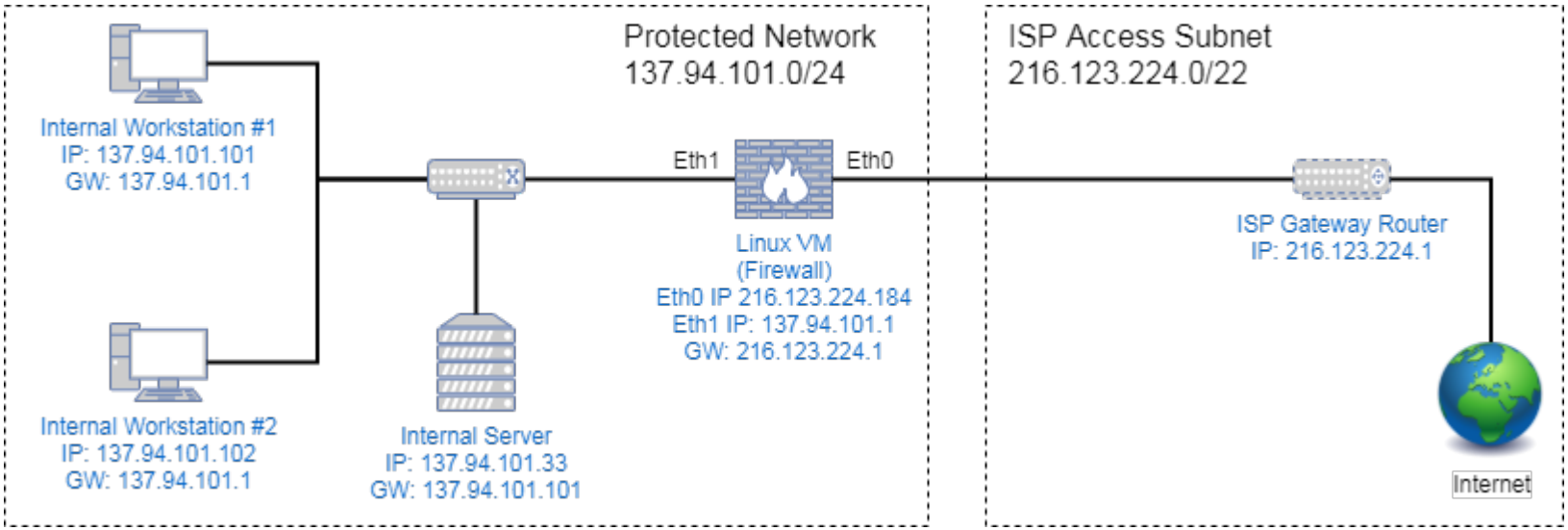

```
#policy
iptables –P INPUT DROP
iptables –P FORWARD DROP
iptables –P OUTPUT DROP

#Allow pinging firewall to anywhere
iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT
iptables -A INPUT -p icmp --icmp-type echo-reply -j ACCEPT

# Allow ping from protected network to anywhere
iptables -A FORWARD –s 137.94.101.0/24 -p icmp --icmp-type echo-request -
        j ACCEPT
iptables -A FORWARD –d 137.94.101.0/24 -p icmp --icmp-type echo-reply -j
        ACCEPT

#Allow ssh
iptables -A FORWARD -s 137.94.101.0/24 -p tcp --dport 22 -m state --state
NEW, ESTABLISHED -j ACCEPT
iptables -A FORWARD -d 137.94.101.0/24 -p tcp --sport 22 -m state --state
ESTABLISHED -j ACCEPT
```

```
#Allow web access
iptables -A FORWARD -s 137.94.101.0/24 -p tcp --dport 80 -m state --state NEW, ESTABLISHED
-j ACCEPT
iptables -A FORWARD -d 137.94.101.0/24 -p tcp --sport 80 -m state --state ESTABLISHED -j
ACCEPT
```

#Allow Web Access to Internal Server

```
Iptables –A FORWARD –d 137.94.101.33 –p tcp –dport 80 -m state --state NEW, ESTABLISHED
        –j
ACCEPT
Iptables –A FORWARD –s 137.94.101.33 –p tcp –sport 80 -m state --state ESTABLISHED -j
        ACCEPT
```

Solution!

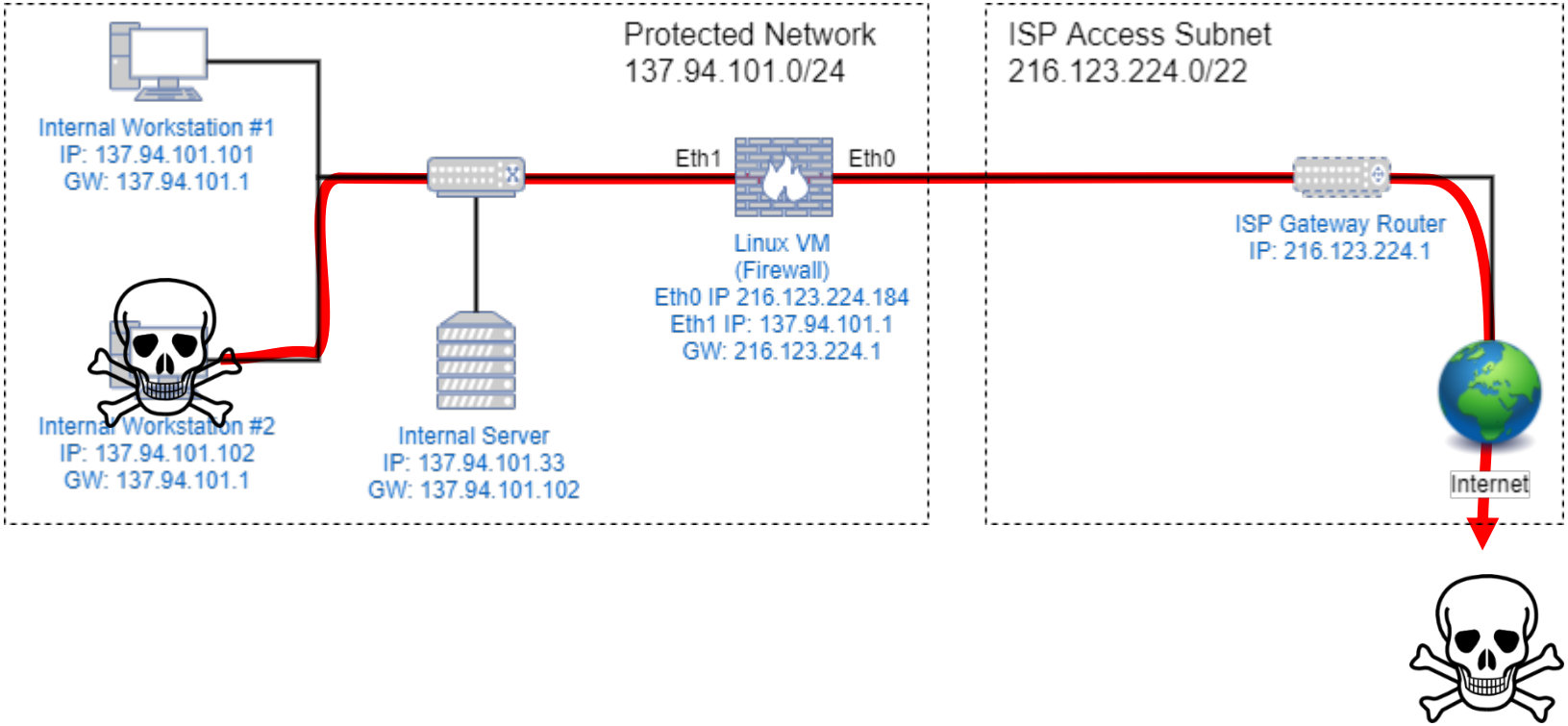


iptables -A FORWARD –i eth0 -s 137.94.x.0/24 -j DROP

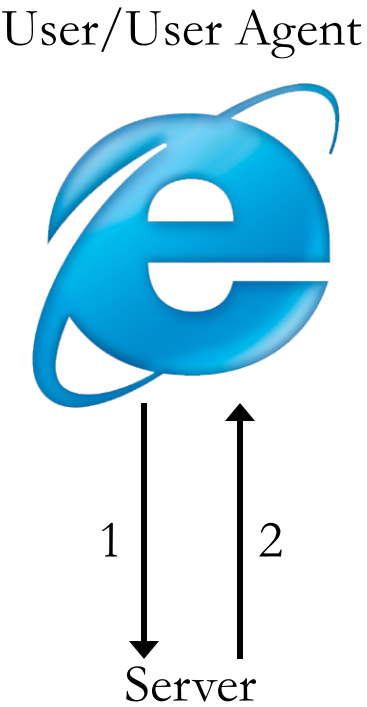
Scenario #5: Subvertion du protocole HTTP

- Vous êtes sur le point de partir au début du long week-end lorsque votre téléphone sonne… Le poste de travail # 2 est à nouveau infecté !!
- Cette fois, le malware se connectait à une machine Internet malveillante sur le port 80.
- Un examen attentif du trafic réseau révèle des commandes et des flux de données illicites cachés dans le trafic HTTP!

Scenario #5 : Subverting HTTP



Scénario d'attaque #5: Subversion du protocole HTTP (1)



1 GET /department/ece/grad_students.html HTTP/1.1

Host: www.rmc.ca

User-Agent: Mozilla/4.0 (compatible; MSIE 5.5; Windows NT 5.0)

2 HTTP/1.1 200 OK

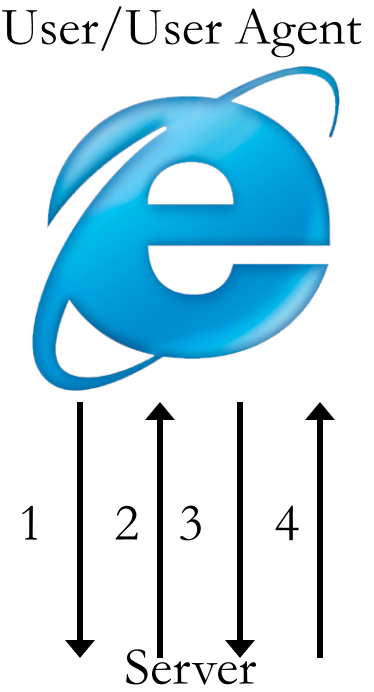
Server: Netscape-Enterprise/6.0

Date: Mon, 26 Feb 2007 03:46:25 GMT

Content-type: text/html

<html>...</html>

Subversion du protocole HTTP (2)




```
1 GET /  HTTP/1.1

2 HTTP/1.1 200 OK
  <html>.blah  blah  blah dir blah..</html>

3 GET /Volume%20in%20Drive%20C%20has%20no%20label
  %2026/03/07%2012:08%20P.M.%20<dir>%20.
  %2026/03/07%2012:08%20P.M.%20<dir>%20..
  %2026/03/07%2012:08 P.M.%20<dir>%20My
  %20Documents HTTP/1.1

4 HTTP/1.1 200 OK

  <html>.blah  blah  blah ipconfig blah..</html>
```

Encodage de tunnels HTTP inversés

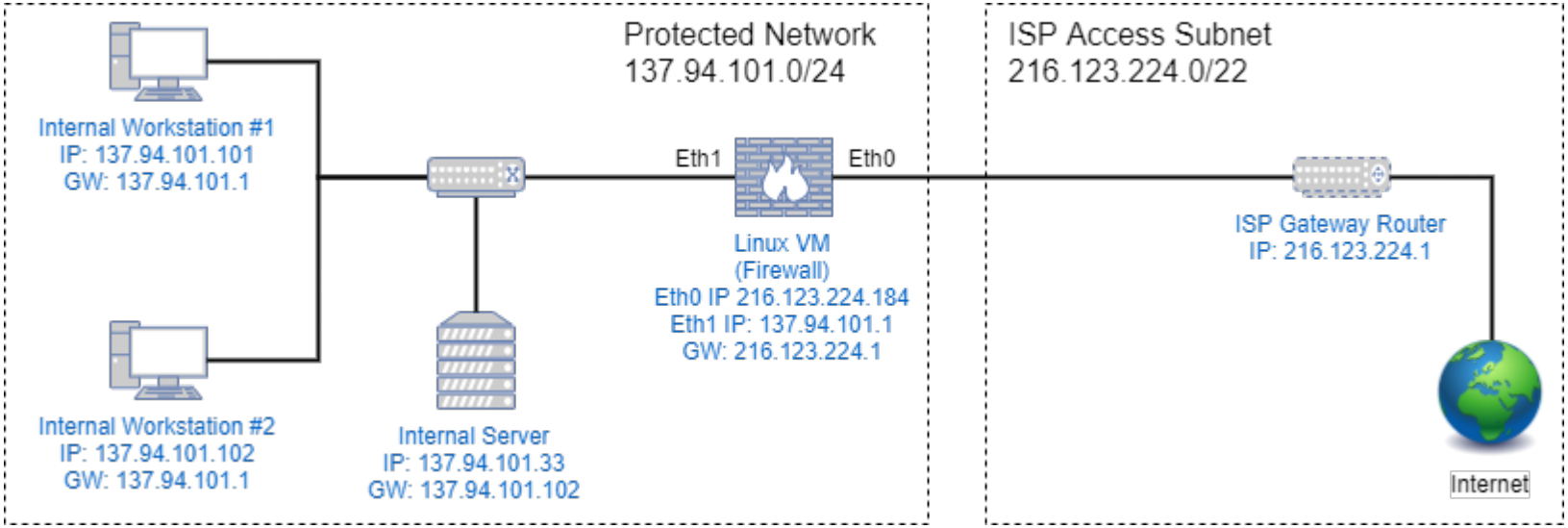
- Les chaines de caractères GET grandissent

```
http://lc2.law13.hotmail.passport.com/cgi_bin/loginerr?curmbox=
F000000001&a=20d9351fd99bfbdd66c9715defff8069&error=4&sec=no&re
auth=&id=2&fs=1&cb=_lang%253dEN&ct=1008617408&_lang=EN&domain=h
otmail%2ecom&utf8=0
```

```
http://119.124.155.107/p99377/rnad.srf?lc=4105&Pd=6528&ru=htQr_
7982626_1265_shx%3fmsu%3d_673kkd/clo2230005=%3fC%nQs%3d1%26msnr
uend%3d1&tw=1000000&kv=2&cbid=6528&ts=_5&da=sdfee.c?%%om&r=20.0
248.1&t=pf=9bf5474785dbfb620f5718cbc965
```

- Évitez les recherches par mots clés
  - Les chaines GET sont encodées (base64)
  - Les réponses sont encodées en HTML
    - Encodage comme graphique ou autre ressource

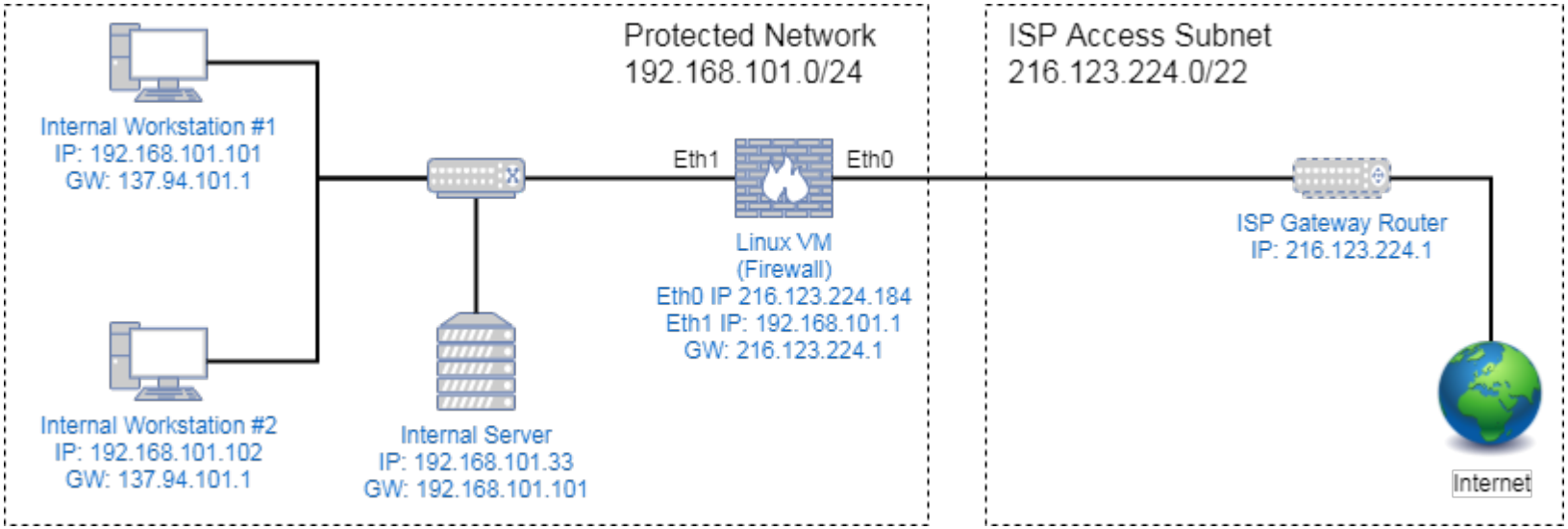
Solution??


Protected Network
137.94.101.0/24
ISP Access Subnet
216.123.224.0/22
Internal Workstation #1
IP: 137.94.101.101
GW: 137.94.101.1
Internal Workstation #2
IP: 137.94.101.102
GW: 137.94.101.1
Internal Server
IP: 137.94.101.33
GW: 137.94.101.102
Eth1
Eth0
Linux VM
(Firewall)
Eth0 IP 216.123.224.184
Eth1 IP: 137.94.101.1
GW: 216.123.224.1
ISP Gateway Router
IP: 216.123.224.1
Internet

Scenario #6: Addressage privé

- On vous demande de répliquer ce déploiement, mais cette fois ci en utilisant la place d'IP 192.168.101.0/24
- Vous répliquez donc votre configuration en changeant les IPs mais cela ne semble pas fonctionner correctement.
- Vos postes de travail ne peuvent pas se connecter vers l'exterieur et votre web server n'est pas accessible depuis Internet.
- Que faut-il faire ?

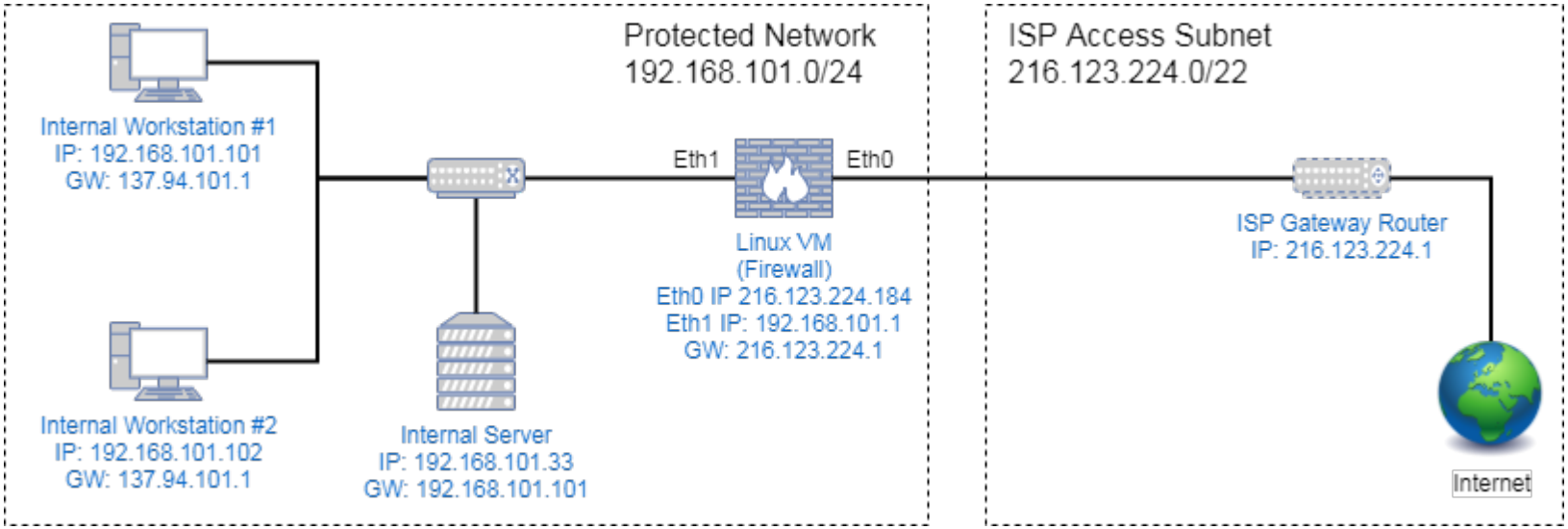
Solution ?




```
#policy
iptables –P INPUT DROP
iptables –P FORWARD DROP
iptables –P OUTPUT DROP

#Allow pinging firewall to anywhere
iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT
iptables -A INPUT -p icmp --icmp-type echo-reply -j ACCEPT

# Allow ping from protected network to anywhere
iptables -A FORWARD –s 192.168.101.0/24 -p icmp --icmp-type echo-request
        -j ACCEPT
iptables -A FORWARD –d 192.168.101.0/24 -p icmp --icmp-type echo-reply -j
        ACCEPT

#Allow ssh
iptables -A FORWARD -s 192.168.101.0/24 -p tcp --dport 22 -m state --state
NEW, ESTABLISHED -j ACCEPT
iptables -A FORWARD -d 192.168.101.0/24 -p tcp --sport 22 -m state --state
ESTABLISHED -j ACCEPT
```

```
#Allow web access
iptables -A FORWARD -s 192.168.101.0/24 -p tcp --dport 80 -m state --state NEW, ESTABLISHED -j
ACCEPT
iptables -A FORWARD -d 192.168.101.0/24 -p tcp --sport 80 -m state --state ESTABLISHED -j
ACCEPT

#Allow Web Access to Internal Server
Iptables –A FORWARD –d 192.168.101.33 –p tcp –dport 80 -m state --state NEW, ESTABLISHED –j
ACCEPT
Iptables –A FORWARD –s 192.168.101.33 –p tcp –sport 80 -m state --state ESTABLISHED -j
        ACCEPT

iptables -A FORWARD –i eth0 -s 192.168.x.0/24 -j DROP
```

Solution !




```
#policy
iptables –P INPUT DROP
iptables –P FORWARD DROP
iptables –P OUTPUT DROP

#Allow pinging firewall to anywhere
iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT
iptables -A INPUT -p icmp --icmp-type echo-reply -j ACCEPT

# Allow ping from protected network to anywhere
iptables -A FORWARD –s 192.168.101.0/24 -p icmp --icmp-type echo-request
        -j ACCEPT
iptables -A FORWARD –d 192.168.101.0/24 -p icmp --icmp-type echo-reply -j
        ACCEPT

#Allow ssh
iptables -A FORWARD -s 192.168.101.0/24 -p tcp --dport 22 -m state --state
NEW, ESTABLISHED -j ACCEPT
iptables -A FORWARD -d 192.168.101.0/24 -p tcp --sport 22 -m state --state
ESTABLISHED -j ACCEPT
```

```
#Allow web access
iptables -A FORWARD -s 192.168.101.0/24 -p tcp --dport 80 -m state --state NEW, ESTABLISHED -j ACCEPT
iptables -A FORWARD -d 192.168.101.0/24 -p tcp --sport 80 -m state --state ESTABLISHED -j ACCEPT

#Allow Web Access to Internal Server
Iptables –A FORWARD –d 192.168.101.33 –p tcp –dport 80 -m state --state NEW, ESTABLISHED –j
ACCEPT
Iptables –A FORWARD –s 192.168.101.33 –p tcp –sport 80 -m state --state ESTABLISHED -j ACCEPT

iptables -A FORWARD –i eth0 -s 192.168.x.0/24 -j DROP

#IP Masquerade
Iptables –t nat –A POSTROUTING –o eth0 –j MASQUERADE

#IP DNAT
iptables –t NAT –A PREROUTING –i eth0 –p tcp –-dport 80 –j DNAT –to-destination 192.168.101.33
```

Prochaine séance:

CONTENTION UDP-TCP